

CONSTRUCTION OS

PRD_11

Platform Administration and
Multi-Company Governance

Creator-level control, tenant lifecycle, custom feature delivery, recovery, support access and oversight

Version	1.0
Date	3 August 2026
Status	Confirmed Scope - Full-Stack Implementation Specification
Audience	Senior Full-Stack Engineering, Product, QA, DevOps, Security and Data Teams

Compatibility rule

This PRD extends the Construction OS master product requirements and all earlier PRDs. Earlier requirements remain authoritative unless this document explicitly amends them.

Contents

- 1 Executive Purpose
- 2 Product Principles
- 3 Administrative Roles and Authority
- 4 Default Tenant Data Isolation
- 5 Company Tenant Lifecycle
- 6 Company Admin Account Recovery
- 7 Temporary Support Access
- 8 Company Onboarding and User Linking
- 9 Company-Specific Feature Lifecycle
- 10 Global Release Management
- 11 Super Platform Admin Oversight and Undo
- 12 Backup and Recovery Governance
- 13 Frontend Requirements
- 14 Backend and Data Requirements
- 15 Security and Audit Requirements
- 16 Acceptance Criteria
- 17 Deferred Decisions

1. Executive Purpose

PRD_11 defines the creator-level administration system for Construction OS. It establishes how the platform creator manages all company tenants without automatically accessing their operational business data, how custom features are delivered per company, how account recovery and technical support work, and how Platform Admin actions are supervised and reversible.

Confirmed product direction

The platform creator operates through a Super Platform Admin account. Additional Platform Admins may be created with limited permissions. Company data is private by default and becomes accessible only through an explicit Company Admin support-access grant.

2. Product Principles

- Tenant isolation is the default. Platform-level authority does not automatically grant access to company projects, HR, finance, contracts, documents or other operational records.
- Platform Admins manage the service, tenant configuration, subscriptions, enabled features, technical health, backups and account recovery.
- Company-specific features must remain isolated, versioned, testable and independently deployable.
- Every privileged action must identify the acting Platform Admin and be written to an immutable audit trail.
- Platform Admin actions take effect immediately. The Super Platform Admin reviews them afterward and may undo them.
- Company Owner authority remains protected. Platform Admins cannot replace a Company Owner after onboarding.

3. Administrative Roles and Authority

Role	Core authority	Restrictions
Super Platform Admin	Creator-level account; defines Platform Admin permissions; reviews all Platform Admin actions; can undo changes; controls platform-wide administration.	Does not receive company operational data access by default.
Platform Admin	Creates and manages tenants; manages features, technical settings, billing metadata, recovery, staged releases and approved support work.	Limited by permissions assigned by Super Platform Admin; no company operational data unless Company Admin grants full support access.
Company Owner	Highest company authority; approves standing authorization for Platform Admin user management; owns formal ownership transfer.	Cannot be assigned or replaced by Platform Admin after onboarding.
Company Admin	Administers the company and may grant or revoke full Platform Admin support access.	Cannot expose another tenant or change platform-level administration.

PA-ROLE-001 One Super Platform Admin

The platform must contain one primary Super Platform Admin role. Additional Platform Admin accounts are subordinate and receive explicit platform permissions assigned by the Super Platform Admin.

PA-ROLE-002 Immediate execution with retrospective oversight

Platform Admin actions do not require prior Super Platform Admin approval. They take effect immediately and are added to the Super Platform Admin oversight queue.

4. Default Tenant Data Isolation

Without support access, Platform Admins may view only tenant account and technical metadata. The following is the maximum default visibility:

Visible metadata	Not visible without support access
Company name, tenant ID and status	Project records, tasks and project documents
Subscription plan and billing status	Contracts, contract values and legal documents
Active-user count and storage usage	Finance, bank, invoices, payments and salaries
Enabled features and feature versions	HR records, attendance details and disciplinary records
System health, error status and backup status	Client, contractor and supplier operational records

PA-DATA-001 No default operational access

Backend authorization must deny Platform Admin access to tenant operational endpoints and storage objects unless an active support-access grant exists for that tenant.

PA-DATA-002 No derived operational analytics

Default metadata must not include anonymized module analytics, project counts, contract totals, workforce statistics or other values derived from operational records.

5. Company Tenant Lifecycle

Action	Platform Admin authority	Required behavior
Create	Allowed	Create tenant, company identity, default configuration and initial Company Owner activation.
Activate	Allowed	Enable company access after onboarding conditions are complete.
Suspend	Allowed	Keep Company Admin access only to billing, support and account settings; block all other users; preserve all data.

Action	Platform Admin authority	Required behavior
Archive	Allowed	Remove tenant from active operation while preserving data, configuration and audit history.
Restore	Allowed	Return an archived or suspended tenant to the applicable active state.
Permanently delete	Not unilateral	Must follow the existing Company Owner request, seven-day standby and Platform Admin approval/deletion process defined in earlier PRDs.

PA-TENANT-001 Suspension access boundary

A suspended company must expose only billing, support and account settings to Company Admins. All other company users are blocked until reactivation.

6. Company Admin Account Recovery

1. The Company Admin starts or requests account recovery.
2. Identity is verified through the registered email plus a second factor: registered phone, authenticator app or recovery code.
3. The Platform Admin generates a secure one-time password or single-use recovery link.
4. At first successful login, the Company Admin must create a new permanent password.
5. The recovery credential expires after use or after the configured security window.
6. The Platform Admin never sees or sets the final permanent password.

PA-REC-001 Recovery audit

Record requester, target account, verification methods, issuing Platform Admin, issue time, expiry, first-use time, completion status and failed attempts. Do not store the one-time credential in readable form.

7. Temporary Support Access

Confirmed exception to default isolation

A Company Admin may grant the Platform Admin full access to the entire company platform for support. The grant has no automatic expiration and remains active until the Company Admin manually revokes it.

Requirement	Behavior
Grant actor	Company Admin only.
Scope	Full tenant access; selected-module support access is not part of this PRD.
Duration	No automatic expiry.
Revocation	Manual revocation by Company Admin.
Permitted actions	View, create, edit, approve, delete, restore, configure and troubleshoot any tenant record or setting.
Audit	Every action must be attributed to the Platform Admin in an immutable log.
Default state	No support access.

PA-SUP-001 Authorization gate

Every tenant API and UI request made by a Platform Admin must verify an active support-access grant before allowing operational data access.

PA-SUP-002 Visible support indicator

Company Admin and Company Owner dashboards must clearly show when Platform Admin support access is active, who received it and when it was granted.

PA-SUP-003 Action attribution

Audit entries and affected records must distinguish Platform Admin support actions from normal Company Admin or employee actions.

8. Company Onboarding and User Linking

- The Platform Admin creates the company tenant and initial Company Owner account.
- The initial Company Owner receives a secure activation link and creates their permanent credentials.
- The Company Owner may grant standing authorization allowing Platform Admins to create users or link existing platform users to the company.
- Standing authorization remains active until the Company Owner revokes it.
- Under standing authorization, the Platform Admin may assign any company role, including Company Admin, except Company Owner.
- Every user creation, link and role assignment must be logged and attributed to the Platform Admin.
- Later ownership changes require a formal transfer initiated by the current Company Owner.

PA-ONB-001 No duplicate identity

When linking an existing platform user, the system must reuse the global user identity and create a tenant membership instead of creating a duplicate account.

9. Company-Specific Feature Lifecycle

The Platform Admin may commission and manage completely custom features for an individual company. A custom feature remains private to the requesting company by default.

Lifecycle stage	Required control
Request registration	Store requesting company, requirement summary, owner, priority and intended scope.
Design/configuration	Separate tenant-specific logic from core platform behavior.
Versioning	Assign independent version and release history.
Testing	Test against the target tenant and regression-test shared platform services.
Deployment approval	Platform Admin approval only. Company Admin or Company Owner approval is not required.
Deployment	Deploy only to the intended tenant through a feature flag or isolated package.
Monitoring	Track errors, performance and adoption after release.
Rollback	Platform Admin may immediately disable or roll back without company approval when errors occur; log the action and notify the company.
Promotion to core	Platform Admin may generalize the feature for all companies without exposing tenant data, confidential configuration or proprietary logic.

PA-FEAT-001 Tenant-safe deployment

A company-specific feature must not alter another tenant schema, workflow, UI or permissions unless separately deployed to that tenant.

PA-FEAT-002 Core promotion separation

Promotion must create a generalized core implementation. The original tenant configuration remains private unless explicitly converted to standard configuration.

10. Global Release Management

Global platform updates must use phased deployment rather than immediate release to every company.

7. Create the global release and its versioned change set.
8. Select one or more test companies.

9. Deploy to the test cohort.
10. Monitor technical health, errors, data migrations and critical workflows.
11. Validate the release.
12. Expand to subsequent cohorts and then platform-wide.
13. Pause or roll back the release when validation thresholds fail.

PA-REL-001 Cohort visibility

The Platform Admin dashboard must show release version, cohort, target companies, deployment state, validation result, rollback state and current percentage of tenants updated.

11. Super Platform Admin Oversight and Undo

The Super Platform Admin requires a dedicated oversight panel focused on Platform Admin approvals and changes, not a duplicate operational tenant dashboard.

Oversight field	Examples
Actor	Platform Admin name and account ID
Action	Tenant created, company suspended, feature deployed, role assigned, support action, global feature changed
Location/scope	Company A, Company B, selected release cohort or overall platform
Timestamp	Start, completion and latest update time
Before/after	Previous and resulting configuration or feature version
Result	Succeeded, partially succeeded, failed, rolled back or undone
Undo eligibility	Available, partially reversible or unavailable with reason

PA-UNDO-001 Automatic exact restoration

When Undo is selected, restore the exact previous configuration or feature version automatically. Where technically possible, restore operational data changes from immutable audit history or backup.

PA-UNDO-002 Undo audit

The undo action is a new immutable event linked to the original action and must identify actor, reason context, restored version, affected scope and result.

Not yet decided

Behavior when an action cannot be safely or fully undone automatically remains deferred. The implementation must expose reversibility metadata so this policy can be added without redesigning the audit model.

12. Backup and Recovery Governance

- A restore request may be initiated by the Company Owner, a Company Admin, or the Platform Admin during a verified technical incident.
- Every request, selected backup, execution, outcome and affected scope must be audited.
- Backup access must not grant general Platform Admin visibility into company data outside the recovery operation.
- The recovery service must support tenant-scoped restore points and protect other tenants from impact.

Deferred confirmation flow

The exact confirmation sequence before restoring a backup - immediate restore, impact confirmation or temporary recovery copy - has not yet been selected.

13. Frontend Requirements

Screen	Minimum functionality
Super Platform Admin overview	Platform Admin activity queue, filters by actor/company/global scope/action/status, before/after comparison and Undo entry point.
Tenant directory	Search and filter companies; display plan, status, active users, storage, features, health, backup and billing metadata only.
Tenant detail	Lifecycle actions, feature assignments, subscription/settings metadata, recovery tools and support-access state; no operational data by default.
Feature management	Custom feature registry, versions, tenant assignment, deployment state, monitoring and rollback.
Global releases	Cohort selection, staged rollout status, validation and rollback controls.
Recovery console	Verified recovery workflow, one-time credential issuance and status tracking.
Support mode	Strong visual banner identifying active tenant, support identity and full-access state.

14. Backend and Data Requirements

Entity/service	Essential fields or behavior
PlatformAdmin	ID, role, status, permissions, created_by_super_admin, MFA status.
Tenant	ID, name, plan, status, storage limit/usage, feature set, health, billing status.
SupportAccessGrant	Tenant, granting Company Admin, Platform Admin or admin scope, granted_at, revoked_at, status.
OwnerStandingAuthorization	Tenant, owner, status, granted_at, revoked_at, allowed action scope.
CustomFeature	Feature ID, tenant, version, state, deployment, rollback version, promotion status.
PlatformChangeEvent	Actor, action, target scope, before snapshot, after snapshot, reversible status, result and linked undo.
Release	Version, cohorts, tenant targets, validation state and rollback state.
RecoveryEvent	Target account/tenant, verification, issuer, token status and completion.
BackupRestoreRequest	Tenant, requester, incident status, backup point, state and audit links.

PA-API-001 Service boundary

Platform-management APIs must be separate from tenant operational APIs. Support mode may authorize operational APIs only through an active grant claim.

PA-API-002 Idempotency

Tenant lifecycle, release deployment, rollback, recovery issuance and undo operations must use idempotency controls to avoid duplicate execution.

PA-API-003 Immutable snapshots

Changes eligible for undo must persist the minimum secure before-state needed to restore the exact prior configuration or version.

15. Security and Audit Requirements

- Require MFA for Super Platform Admin and Platform Admin accounts.
- Use least-privilege Platform Admin permissions assigned by Super Platform Admin.
- Log successful and denied privileged actions.
- Prevent Platform Admins from deleting or altering their own audit events.
- Encrypt recovery tokens and expire them after first use or configured timeout.

- Apply strong re-authentication for tenant deletion approval, support access activation, role assignment, rollback and undo.
- Preserve tenant ID and support-mode context in every request trace and audit event.
- Notify affected companies after custom-feature rollback and other service-impacting actions.

16. Acceptance Criteria

ID	Acceptance criterion
AC-11-01	A Platform Admin can open a tenant detail page without being able to open any project, contract, HR, finance or document record.
AC-11-02	A Company Admin can grant full support access; the Platform Admin can then operate across the tenant, and every action is attributed to the Platform Admin.
AC-11-03	Support access remains active until the Company Admin manually revokes it.
AC-11-04	A recovery link is issued only after registered-email and second-factor verification and requires a new password on first login.
AC-11-05	A custom feature can be deployed to one company without changing another company.
AC-11-06	The Platform Admin can immediately roll back a faulty custom feature and the company is notified.
AC-11-07	A suspended company blocks standard users while Company Admins retain billing, support and account settings access.
AC-11-08	The Super Platform Admin panel shows who changed what, when and where, including tenant-specific and overall platform changes.
AC-11-09	Undo restores the previous configuration or feature version and creates a linked audit event.
AC-11-10	Under standing owner authorization, Platform Admin can create/link users and assign Company Admin, but cannot assign Company Owner.
AC-11-11	A global update can be deployed to selected test companies before platform-wide rollout.

17. Deferred Decisions

- Behavior when a Platform Admin action is only partially reversible or cannot be safely undone.
- Final confirmation workflow and preview method before a company backup restore.
- Subscription, billing, user-limit, storage-limit and trial-period editing authority.
- Whether support-access grants should later support selected modules or automatic expiration.
- Notification recipients and cadence for Super Platform Admin retrospective reviews.